

session-6

درسنامه: امنیت، معماری و پروتکل HTTP

بخش اول: مفاهیم پایه امنیت شبکه

امنیت شبکه یک حوزه بسیار بزرگ و پیچیده است که اکنون به یکی از شاخه‌های اصلی شبکه تبدیل شده است. تأمین امنیت به‌ویژه در اینترنت، به دلیل آنکه اینترنت خود شبکه‌ای از شبکه‌ها (Network of Networks) است، بسیار دشوار است.

۱.۱. ماهیت حمله و دفاع

مسئله امنیت شبیه معمای مرغ و تخم‌مرغ است (چرخه حمله و دفاع)؛ همواره در دنیا با تولید مکانیزم‌های دفاعی، حملات جدیدی نیز طراحی می‌شوند. دلایل حمله می‌توانند بسیار متفاوت باشند، از دلایل قاطعانه (سیاسی، اقتصادی، فرهنگی) تا دلایل شخصی و بیهوده (آزار روانی، اذیت کردن یا خودنمایی).

۱.۲. بدافزارها (Malware)

بدافزار یا **Malware** (مخفف Malicious Software) یک نام واحد و فراگیر است که تمام نرم‌افزارهای مخرب را زیرمجموعه خود قرار می‌دهد.

نوع بدافزار	تعریف و عملکرد	ویژگی کلیدی	منابع
ویروس (Virus)	یک فایل مخرب است که برای پخش شدن حتماً باید فعال (اجرا) شود . اغلب مردم در دنیا از اصطلاح "ویروس" برای اشاره به هر نوع آلودگی رایانه‌ای استفاده می‌کنند، زیرا مفهوم اصلی آن همه‌گیری است.	نیاز به اجرا دارد.	
کرم (Worm)	برخلاف ویروس، نیازی به اجرا شدن توسط کاربر ندارد و خودش به صورت خودکار پخش می‌شود.	خودکار پخش می‌شود.	
تروجان (Trojan) (Horse)	اسب تروجان یکی از سه نوع معروف‌ترین و شاید ساده‌ترین بدافزارهای معمول در شبکه است.	در کنار ویروس و کرم، بسیار معروف است.	
اسپای‌ور (Spyware)	بدافزارهای جاسوسی که معمولاً برای جمع‌آوری اطلاعات خاص مانند یوزرنیم و پسورد استفاده می‌شوند.	جاسوسی و جمع‌آوری اطلاعات.	
ادور (Adware)	بدافزارهای تبلیغاتی که باعث نمایش آگهی‌های عجیب و غریب در سیستم می‌شوند (معمولاً بر اساس جستجوهای کاربر).	ایجاد آگهی‌های مزاحم.	

۱.۳. حملات مهم شبکه

برخی از حملات بسیار قدیمی و رایج هستند که همچنان مورد استفاده قرار می‌گیرند:

۱. حمله منع سرویس توزیع شده (DDoS) و منع سرویس (DoS):

- **عملکرد:** ارسال حجم بسیار زیادی درخواست به سمت سرور، که باعث می‌شود سرور نتواند پاسخگو باشد و عملاً از دسترس خارج شود.
- حمله از طریق **یک** سیستم مخرب در شبکه انجام می‌شود: **DoS (Denial of Service)**.
- حمله از طریق **تعداد زیادی** سیستم مخرب انجام می‌شود: **DDoS (Distributed Denial of Service)**.
- **مثال‌های واقعی:** از دسترس خارج شدن سایت‌ها هنگام ثبت‌نام‌های پرترافیک (مثل ثبت‌نام دانشگاه یا خودرو) که ناشی از حجم بالای لاگین‌ها است، رفتاری مشابه حمله DDoS دارد.

- **دفاع:** ابزارهایی برای تشخیص ربات‌ها (مثل کپچا) به کار می‌روند تا مشخص شود درخواست از یک **آی‌پی واقعی** می‌آید یا یک سیستم جعلی.
- 2. **شنود پکت (Packet Sniffing):**
 - در واقع مانند یک شنونده عمل می‌کند و اطلاعات در حال جابه‌جایی در شبکه را شنود و ضبط می‌کند تا در موقع لزوم از آن‌ها استفاده کند.
- 3. **جعل آی‌پی (IP Spoofing):**
 - در این حمله، یک سیستم با استفاده از یک **آی‌پی جعلی** وارد شبکه می‌شود و وانمود می‌کند که سیستم دیگری است. سپس درخواست‌ها را ارسال و اطلاعات را دریافت می‌کند.
 - **اهداف رایج:** برای کاربران عادی، حملات اغلب شامل اطلاعات بانکی، شخصی یا کپی کردن عکس‌ها است.

بخش دوم: لایه کاربرد و معماری برنامه‌های کاربردی

از این بخش، تمرکز بر روی لایه‌های مدل TCP/IP و به‌طور خاص لایه کاربرد (لایه پنجم) است. لازم به ذکر است که لایه‌های شبکه یک **مفهوم انتزاعی** هستند و وجود فیزیکی ندارند.

۲.۱. کاربردهای شبکه (اپلیکیشن‌های لایه کاربرد)

کاربردهایی که شما از شبکه و اینترنت دریافت می‌کنید، شامل موارد زیر است:

- وب‌گردی (Web Browsing)
- ایمیل (Email)
- پیام‌رسانی و چت (Instant Messaging/Chat)
- به اشتراک‌گذاری فایل (File Sharing)
- بازی‌ها (Games)
- جریان ویدیو (Video Streaming) و کنفرانس تصویری
- تلفن بر بستر اینترنت (VoIP/Voice over IP)
- لاگین از راه دور (Remote Logging)
- رایانش شبکه‌ای (Grid Computing)

۲.۲. معماری برنامه‌های کاربردی

برای ارتباط اپلیکیشن‌ها در شبکه، دو مدل معماری کلی (و یک مدل ترکیبی) وجود دارد:

ویژگی	معماری کلاینت-سرور (Client-Server)	معماری همتا به همتا (Peer-to-Peer - P2P)
تعریف	یک سیستم (سرور) سرویس‌دهنده است (با آی‌پی ثابت) و یک یا چند سیستم (کلاینت) سرویس‌گیرنده هستند.	تمام سیستم‌ها هم‌تراز هستند و در لحظه می‌توانند هم سرویس بدهند و هم سرویس بگیرند.
در دسترس بودن	سرور همیشه آنلاین و در دسترس است (مشخصه حیاتی).	سرور همیشه آنلاین نیست.
مزیت کلیدی	همیشه در دسترس بودن.	در صورت خارج شدن یک سیستم از دسترس، سیستم‌های دیگر جایگزین آن می‌شوند و کار شبکه متوقف نمی‌شود (انعطاف‌پذیری بالا).
عیب کلیدی	اگر سرور از کار بیفتد (نرم‌افزاری، قطعی برق و...)، ارتباط قطع شده و عملاً هیچ پاسخ‌دهنده‌ای در شبکه وجود ندارد.	تضمین آنلاین بودن از بین می‌رود.

ویژگی	معماری کلاینت-سرور (Client-Server)	معماری هم‌تا به هم‌تا (Peer-to-Peer - P2P)
ارتباط کلاینت‌ها	کلاینت‌ها به صورت مستقیم با یکدیگر در ارتباط نیستند.	تمام سیستم‌ها به صورت مستقیم با یکدیگر در ارتباطند.

معماری هیبرید (Hybrid): مدلی ترکیبی از کلاینت-سرور و P2P است. **اسکایپ** مثالی از معماری هیبرید بود که از کلاینت-سرور برای ذخیره اطلاعات (اکانت و فایل) و از P2P برای چت همزمان و ارتباطات لحظه‌ای استفاده می‌کرد.

بخش سوم: فرایندها و نقاط اتصال

۳.۱. فرایند (Process)

فرایند در شبکه به برنامه‌ای گفته می‌شود که بر روی میزبان (Host) در حال اجراست.

- **ارتباط داخلی:** فرایندهای مختلف می‌توانند درون یک سیستم در حال اجرا باشند (مانند همزمان ایمیل زدن، چت کردن و پخش ویدیو).
- **ارتباط خارجی:** فرایندها روی دو سیستم مختلف در شبکه در حال اجرا هستند.

فرایندها دو نقش اصلی دارند (حتی در P2P):

1. **فرایند کلاینت (Client Process):** فرایندی که **درخواست** ارتباط می‌کند.
2. **فرایند سرور (Server Process):** فرایندی که **منتظر** است تا از آن درخواست شود (سرویس‌دهنده).

۳.۲. سوکت و پورت

سوکت (Socket): سوکت به معنی **نقطه پایان یک ارتباط دوطرفه** در شبکه است. وظیفه آن توزیع داده‌ها از طریق کانال ارتباطی است.

- **ساختار سوکت:** سوکت شامل ترکیب **آدرس آی‌پی** و **شماره پورت** است.
- **پورت (Port):** پورت یک عدد (درگاه) است.
- **رابطه سوکت و پورت:** یک سوکت تنها به **یک پورت** وصل می‌شود، اما **یک پورت** می‌تواند با **چندین سوکت** در ارتباط باشد.

آدرس‌دهی: برای برقراری ارتباط (چون سوکت نقطه ارتباط است)، سیستم باید علاوه بر شماره آی‌پی، یک **شماره پورت** نیز داشته باشد. شماره پورت‌ها اعداد قراردادی هستند که برای پروتکل‌های مختلف تعیین شده‌اند (مثلاً پورت ۸۰ برای HTTP).

بخش چهارم: پروتکل HTTP

است. این پروتکل، مجموعه‌ای از قوانین برای (پروتکل انتقال فرامتن) **Hypertext Transfer Protocol** مخفف **HTTP** انتقال فایل‌ها (متن، عکس، ویدیو، صدا و...) از طریق وب است.

۴.۱. اشیاء وب و آدرس‌دهی (URL)

هر چیزی که در یک صفحه وب وجود دارد (فایل HTML، عکس، فایل صوتی/تصویری، دکمه و...) یک **شیء (Object)** محسوب می‌شود.

- برای آدرس‌دهی این اشیاء استفاده می‌شود: **URL (Uniform Resource Locator)**.

• **ساختار URL (نمونه):** `HTTP://Host/Path`

- ۱. پروتکل (Protocol): مانند HTTP.
- ۲. میزبان (Host): آدرس سایت شامل تاپ لول دامین، دامین و ساب دامین.
- ۳. مسیر (Path): مسیری که به یک عکس، ویدیو یا صفحه دیگر ختم می شود.
- ۴. پارامترها (Query/Parameters): اطلاعات اضافی که ممکن است بر اساس متد GET یا POST نمایش داده شوند.

۴.۲. عملکرد پایه HTTP

عملکرد HTTP بسیار ساده است: کلاینت یک درخواست (Request) برای دریافت فایل به سرور ارسال می کند و سرور پاسخ (Response) خود را به کلاینت برمی گرداند.

۴.۳. حالت های HTTP

پروتکل HTTP دو حالت برای برقراری ارتباط دارد:

۱. ناپایدار (Non-Persistent): در هر ارتباط تکی سی پی بین سرور و کلاینت، فقط یک شیء جابه جا می شود. ارتباط پس از انتقال شیء قطع می شود و برای شیء بعدی باید دوباره درخواست ارتباط داده شود.
۲. پایدار (Persistent): در هر ارتباط تکی سی پی، چندین شیء (Multi-Object) ارسال می شود. در این حالت، هنگامی که یک صفحه باز می شود، تمام فایل ها بارگذاری می شوند.

۴.۴. زمان رفت و برگشت (RTT)

زمانی است که یک بسته داده (پکت) از کلاینت به سمت سرور رفته و بازمی گردد: RTT (Round-Trip Time).

- زمان انتقال فایل (در حالت ناپایدار): برای هر ارتباط، دو RTT زمان می برد (یکی برای برقراری اتصال و دیگری برای ارسال درخواست و دریافت پاسخ)، به علاوه زمان انتقال واقعی فایل.

$$\text{لایف لایت نامز} = (2 \times \text{RTT}) + \text{لایف لایت نامز}$$

بخش پنجم: پیغام های HTTP (ریکوست)

ارتباطات HTTP در دو مدل پیغام خلاصه می شود: ریکوست (درخواست) و ریسپانس (پاسخ).

۵.۱. ساختار پیغام ریکوست (Request Message)

هر پیغام ریکوست شامل سه بخش اصلی است که توسط اسپیس از هم جدا می شوند:

۱. خط درخواست (Request Line):
 - مهم ترین بخش پیغام است.
 - شامل سه جزء است که با اسپیس جدا می شوند: نوع دستور (متد)، آدرس (URL)، و ورژن پروتکل HTTP.
۲. خطوط هدر (Header Lines):
 - شامل اطلاعات عمومی و دلخواه است (مانند نام هاست، نوع مرورگر یا زبان سیستم).
۳. بدنه (Body/Entity Body):
 - اطلاعاتی است که قرار است ارسال شود (مثل فایل).

۵.۲. نسخه های پروتکل HTTP

ما دو نسخه اصلی HTTP داریم:

۵.۳. متدهای HTTP (نوع دستور)

نوع دستوری که در خط درخواست می‌آید، مشخص می‌کند کلاینت قصد انجام چه کاری را دارد. متدهای اصلی عبارتند از:

متد	کاربرد	توضیح	نسخه
GET	واکشی داده (Retrieval)	برای گرفتن داده یا فایل از سرور استفاده می‌شود.	۱.۰ و ۱.۱
POST	ارسال داده	برای ارسال داده به سرور (مانند آپلود فایل یا عکس) استفاده می‌شود.	۱.۰ و ۱.۱
HEAD	واکشی هدر	مشابه GET، اما سرور فقط هدر را برمی‌گرداند و بدنه (Body) پیغام حذف می‌شود. این روش سریع‌تر از GET است.	۱.۰ و ۱.۱
PUT	جایگزینی منبع	برای جایگزینی یک منبع موجود در سرور استفاده می‌شود.	۱.۱
DELETE	حذف منبع	برای حذف یک منبع از سرور استفاده می‌شود.	۱.۱
TRACE	اشکال‌زدایی	برای ردگیری (Tracing) و اشکال‌زدایی استفاده می‌شود.	۱.۱
CONNECT	ایجاد ارتباط TCP	برای ایجاد یک ارتباط تی‌سی‌پی (TCP Connection) ارسال می‌شود.	۱.۱
OPTIONS	توصیف گزینه‌ها	برای توصیف گزینه‌های ارتباطی (مثلاً پشتیبانی از یک قابلیت) استفاده می‌شود.	۱.۱

جمع‌بندی (تمثیل)

اگر بخواهیم ارتباطات شبکه را با یک سازمان اداری مقایسه کنیم:

- امنیت شبکه:** مانند دیوارهای امنیتی و نگهبانان سازمان است. حملات (مانند ویروس و کرم) افرادی هستند که سعی می‌کنند با روش‌های مختلف (اجرا شدن یا پخش خودکار) از این دیوار عبور کنند.
- معماری کلاینت-سرور:** شبیه سازمان‌های متمرکز است که یک مدیر (سرور) در دسترس دارد. اگر مدیر نباشد، تمام کارها متوقف می‌شود.
- معماری P2P:** شبیه سازمان‌های غیرمتمرکز است که هر کارمند می‌تواند وظیفه مدیر را انجام دهد. اگر یک کارمند غایب باشد، بقیه کار را ادامه می‌دهند.
- سوکت:** آدرس دقیق میز شما (ترکیب آی‌پی ساختمان و شماره پورت میز کار) است که نامه‌ها (داده‌ها) باید به آنجا برسند.
- پروتکل HTTP:** روش ارسال و دریافت نامه‌هاست (ریکوست و ریسپانس). حالت ناپایدار مانند این است که برای هر سند، باید یک بار نامه‌رسان را صدا بزنید (قطع و وصل شدن)، اما در حالت پایدار، نامه‌رسان منتظر می‌ماند تا چندین سند را همزمان تحویل دهد.
- RTT:** زمان لازم برای رفت و برگشت یک بسته نامه است تا بفهمیم که نامه‌رسان چقدر طول می‌کشد تا پیام شما را به مقصد ببرد و پاسخ تأیید را برگرداند.